

SÉCURITÉ DES APPLICATIONS WEB

# Guide du TP 1 : lire HTTP, les cookies et un certificat sans se tromper

TP 1 · HTTP, cookies et en-têtes

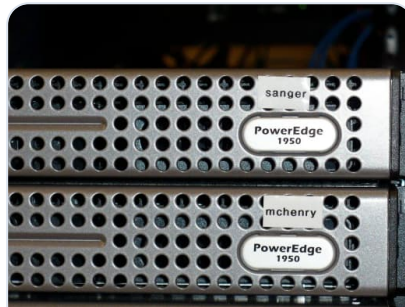


## MATÉRIEL QUE TU CROISES DANS CE LABORATOIRE



### Ordinateur portable

L'ordinateur que l'on emporte partout



### Serveur

Fournit fichiers, messagerie ou site web aux autres

Photos issues de Wikimedia Commons : Ordinateur portable, Ahunt, CC0 · Serveur, Florence Devouard, CC BY-SA 4.0.

## CADRE ET LIMITES

- ◆ Les exemples de ce guide utilisent des valeurs inventées, pas celles du labo.
- ◆ Tu analyses uniquement des fichiers fournis ; ne teste jamais un système réel sans autorisation écrite.
- ◆ Ne colle jamais un jeton ou un mot de passe réel dans un navigateur, un terminal ou un outil en ligne.

## Lire un échange HTTP

- ◆ Une requête HTTP/1.1 contient une ligne de requête, des en-têtes puis un corps éventuel.
- ◆ Une réponse HTTP/1.1 contient une ligne d'état, des en-têtes puis un corps éventuel.
- ◆ Le champ « Location » sert à suivre une redirection. « Set-Cookie » annonce un cookie. « Server » et « X-Powered-By » peuvent divulguer une technologie ou une version.

## Lire un cookie

- ◆ « Secure » limite le cookie à HTTPS.
- ◆ « HttpOnly » empêche sa lecture par JavaScript dans le navigateur.
- ◆ « SameSite=None » exige aussi « Secure ».
- ◆ « Max-Age » s'exprime en secondes. Pour des minutes, divise par 60. Pour des jours, divise par 86400.



## Lire un certificat

- ◆ Le champ SAN liste les noms d'hôtes couverts.
- ◆ « notAfter » donne la date de fin de validité.
- ◆ Pour compter des jours restants, compare deux dates en UTC puis retiens un nombre entier de jours.



## Bash ou Git Bash

BASH

```
cat > demo-http.txt <<'EOF'
HTTP/1.1 302 Found
Location: https://boutique-exemple.example/accueil
Set-Cookie: session_demo=abc123; Path=/; Max-Age=1800; HttpOnly; Secure; SameSite=Lax
Set-Cookie: theme_demo=sombre; Path=/; Max-Age=86400; SameSite=Lax
EOF
redir_demo=$(grep -c '^HTTP/1.1 3' demo-http.txt)
cookie_demo=$(grep '^Set-Cookie:' demo-http.txt | cut -d: -f2- | cut -d= -f1 | tr -d ' ' | head -n 1)
minutes_demo=$(grep '^Set-Cookie:' demo-http.txt | head -n 1 | sed -E 's/.*Max-Age=([0-9]+).*/\1/' | awk '{print int($1/60)}')
jours_demo=$(( ( $(date -u -d '2026-03-20T00:00:00Z' +%s) - $(date -u -d '2026-03-10T00:00:00Z' +%s) ) / 86400 ))
printf 'Redirections demo : %s\nPremier cookie demo : %s\nDuree demo en minutes : %s\nJours demo : %s\n' "$redir_demo" "$cookie_demo" "$minutes_demo" "$jours_demo"
```

Commande longue, coupée par la mise en page : copie-la en une seule ligne ou utilise la version texte indiquée en fin de document.



## PowerShell 5.1

Les fichiers du labo sont en UTF-8 : avec Windows PowerShell 5.1, garde l'option -Encoding UTF8 de Get-Content quand tu lis un fichier.

POWERSHELL

```
@'
HTTP/1.1 302 Found
Location: https://boutique-exemple.example/accueil
Set-Cookie: session_demo=abc123; Path=/; Max-Age=1800; HttpOnly; Secure; SameSite=Lax
Set-Cookie: theme_demo=sombre; Path=/; Max-Age=86400; SameSite=Lax
'@ | Set-Content -Encoding UTF8 demo-http.txt
$demo = Get-Content -Encoding UTF8 demo-http.txt
$redirDemo = @($demo | Where-Object { $_ -match '^HTTP/1.1 3' }).Count
$firstCookie = (($demo | Where-Object { $_ -like 'Set-Cookie:*' })[0] -split ': ' | Select-Object -First 1)
$maxAge = [int]($demo | Where-Object { $_ -like 'Set-Cookie:*' })[0] -replace '.*Max-Age=([0-9]+).*', '$1')
$minutesDemo = [int]($maxAge / 60)
$daysDemo = ([datetime]'2026-03-20T00:00:00Z' - [datetime]'2026-03-10T00:00:00Z').Days
"Redirections demo : $redirDemo"
"Premier cookie demo : $firstCookie"
"Duree demo en minutes : $minutesDemo"
"Jours demo : $daysDemo"
```

Commande longue, coupée par la mise en page : copie-la en une seule ligne ou utilise la version texte indiquée en fin de document.



## Visionneuse du site

Dans la visionneuse, cherche d'abord des mots génériques comme « Location », « Set-Cookie », « Strict-Transport-Security », « Content-Security-Policy » ou « DNS: ». Ensuite, relis la ligne complète et garde son contexte immédiat.



### Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite. Pour copier les commandes sans coupure de ligne, ouvre la [version texte](#).